

Central Legal Advisors

Auditoría de Sistemas de Información
COBIT 5 y Dominio DSS

INFORME FINAL DE AUDITORÍA



Dirigido a:
Gerencia General

Elaborado por:
Auditors Inc.

FECHA DE ENTREGA:
Junio 2026

PERIODO EVALUADO:
Mayo 2026

RESUMEN EJECUTIVO	2
INTRODUCCIÓN	3
PROGRAMA DE AUDITORIA	5
RESULTADOS	10
CONCLUSIONES.....	21
ANEXOS	22
Instrumentos	22
INSTRUMENTO DE EVALUACIÓN DE CUMPLIMIENTO BASADO EN LAS DISPOSICIONES TÉCNICAS DGI	25
Observación Directa	27
Evidencia de Hallazgos.....	30

Durante mayo de 2026, se llevó a cabo una auditoría informática en Central Legal Advisors, empresa especializada en la optimización de procesos de admisión legal para firmas dentro del sector BPO jurídico. La evaluación abarcó el sistema de información de la organización, centrándose en el control interno informático, seguridad de la información, gestión de accesos, continuidad operativa y cumplimiento normativo. Para ello, se empleó un enfoque basado en riesgos, utilizando el marco metodológico COBIT 5 (dominio DSS) y los controles de la norma ISO/IEC 27001.

El análisis evidenció deficiencias relevantes en el control interno informático de la empresa. Aunque existe una infraestructura tecnológica funcional y procesos básicos documentados, se detectó una brecha considerable entre el diseño de políticas y su aplicación práctica. Esta situación compromete la confidencialidad, integridad y disponibilidad de la información, ubicando a la organización en un nivel de madurez intermedio, pero expuesta a riesgos operativos y legales significativos.

Se identificaron siete hallazgos principales:

- Ausencia de autenticación multifactor (MFA).
- Usuarios operativos con capacidad de exportar información de leads sin restricciones.
- Personal encargado de calificar leads con acceso a funciones no autorizadas, como eliminar leads y descargar grabaciones.
- Roles operativos con permisos de administrador en el CRM.
- Falta de un Plan de Recuperación ante Desastres y de pruebas de restauración.
- Uso de credenciales genéricas y compartidas en el sistema de llamadas, lo que impide la trazabilidad individual.
- Configuración inadecuada del dialer, lo que provoca múltiples llamadas en menos de un minuto a un mismo lead y afecta la experiencia del cliente, generando riesgos reputacionales.

Estos hallazgos reflejan la necesidad de fortalecer los controles internos y la gestión de riesgos tecnológicos para garantizar la seguridad y eficiencia operativa en Central Legal Advisors.

La auditoría informática realizada en Central Legal Advisors tuvo como propósito evaluar la eficacia de los controles internos informáticos de la organización, considerando la importancia de proteger la información sensible gestionada mediante sus sistemas tecnológicos.

El trabajo se desarrolló siguiendo un enfoque basado en riesgos, con referencia principal al marco COBIT 5 (dominio DSS) y los controles de la norma ISO/IEC 27001, lo que permitió analizar la operación de los servicios tecnológicos, mecanismos de seguridad, gestión de accesos, continuidad operativa y cumplimiento normativo.

1.1 Objetivos de la Auditoría

Objetivo General:

Evaluar la eficacia de los controles internos informáticos en Central Legal Advisors, aplicando procedimientos de auditoría basados en COBIT 5 y los controles establecidos por la norma ISO/IEC 27001.

Objetivos Específicos:

- Diagnosticar el estado actual de los controles internos informáticos.
- Evaluar el cumplimiento de políticas internas y normativas en materia de seguridad de la información y protección de datos.
- Identificar hallazgos, riesgos y oportunidades de mejora en los procesos tecnológicos.
- Formular recomendaciones para fortalecer los controles internos y la gestión de riesgos tecnológicos.

1.2 Alcance de la Auditoría

El alcance incluyó la evaluación del sistema de información de Central Legal Advisors, con énfasis en la eficacia de los controles internos y los mecanismos de seguridad para proteger la información.

Las áreas revisadas fueron:

- Gestión de accesos y control de usuarios
- Seguridad de la información y protección de datos
- Configuración y operación de sistemas tecnológicos
- Infraestructura tecnológica y servicios en la nube
- Continuidad operativa y procedimientos de respaldo
- Monitoreo, control y cumplimiento de políticas internas

1.3 Metodología Aplicada

La auditoría se realizó bajo un enfoque basado en riesgos, con el marco COBIT 5 (dominio DSS) y los controles de la norma ISO/IEC 27001 como referentes principales. Se emplearon entrevistas, cuestionarios, listas de verificación, revisión documental y observación directa para obtener evidencia suficiente y confiable, lo que permitió emitir conclusiones y recomendaciones enfocadas en el fortalecimiento de los controles internos y la gestión de riesgos tecnológicos.

PROGRAMA DE AUDITORIA

El programa de auditoría se estructura en siete fases, comenzando con la planificación y contextualización, programada del 4 al 6 de mayo de 2026. La segunda fase abarca la operación de servicios, prevista para los días 7 y 8 de mayo. La gestión de incidentes y problemas se realizará el 11 de mayo, seguida de la continuidad de servicios a partir del 12 de mayo. La revisión de la seguridad de los servicios está programada para los días 13 y 14 de mayo. Posteriormente, los controles del negocio se abordarán el 15 de mayo, y la fase de cierre se realizará del 18 al 19 de mayo de 2026, tal como se ilustra en la figura 1.

Figura 1

							PROGRAMA DE AUDITORÍA						
Central Legal Advisors													
CÓDIGO		001		VIGENCIA		2026		FECHA		04/15/2026			
FASES DE EJECUCIÓN													
FASE I PLANIFICACIÓN Y CONTEXTUALIZACIÓN			FASE II OPERACIÓN DE SERVICIOS (DSS01)		FASE III GESTIÓN DE INCIDENTES Y PROBLEMAS (DSS02 – DSS03)		FASE IV CONTINUIDAD DE SERVICIOS (DSS04)		FASE V SEGURIDAD DE SERVICIOS (DSS05)		FASE VI CONTROLES DEL NEGOCIO (DSS06)		FASE VII CIERRE

FECHA	HORA	ACTIVIDAD	AUDITOR	PROCESO A AUDITAR	PROCESO DSS	ACTIVIDADES A REALIZAR	RESPONSABLE
04/05/2026	09:00 – 12:00	Reunión de planificación y coordinación del programa de auditoría	Auditor Líder, Equipo Auditor	Dirección y planificación de auditoría	Fase I	Definir conjuntamente el programa de auditoría, cronograma, alcance, responsables, criterios de evaluación y técnicas de auditoría basadas en COBIT 5 DSS e ISO/IEC 27001.	Equipo auditor, Gerencia General

04/05/2026	13:00 – 17:00	Análisis del contexto organizacional y servicios tecnológicos críticos	Equipo auditor	Gestión organizacional y tecnológica	Fase I	Analizar la estructura organizacional, procesos críticos, servicios tecnológicos y entorno operativo que soporta las actividades de la empresa.	Equipo auditor, Gerencia General
05/05/2026	08:00 – 12:00	Estudio del marco normativo y metodológico aplicable	Equipo auditor	Cumplimiento normativo y controles TI	Fase I	Verificar el marco normativo aplicable, incluyendo COBIT 5 DSS, ISO/IEC 27001 y legislación nacional, con el fin de establecer los criterios de auditoría y cumplimiento.	Equipo auditor
05/05/2026	13:00 – 17:00	Definición del alcance y procesos DSS a evaluar	Auditor líder	Dirección de auditoría	Fase I	Determinar el alcance, objetivos específicos, procesos DSS y controles tecnológicos que serán evaluados durante la auditoría.	Auditor líder
06/05/2026	08:00 – 12:00	Identificación y clasificación de activos tecnológicos críticos	Auditor TI	Infraestructura y activos tecnológicos	Fase I	Identificar y clasificar activos de información, sistemas críticos, CRM, dialers, bases de datos y recursos tecnológicos vinculados a la operación del servicio.	Auditor TI

06/05/2026	13:00 – 17:00	Evaluación preliminar de riesgos tecnológicos	Equipo auditor	Gestión de riesgos TI	Fase I	Identificar amenazas, vulnerabilidades e impactos asociados a los servicios tecnológicos y a la seguridad de la información, bajo un enfoque basado en riesgos.	Equipo auditor
07/05/2026	08:00 – 12:00	Evaluación de operaciones de servicios tecnológicos	Auditor TI	Operaciones tecnológicas	DSS01	Verificar la eficacia operativa de los servicios tecnológicos críticos mediante la evaluación de configuraciones, disponibilidad, soporte operativo y funcionamiento del CRM, dialers y herramientas de automatización.	Auditor TI
07/05/2026	13:00 – 17:00	Revisión de monitoreo operativo y trazabilidad de servicios	Auditor TI	Monitoreo y control operativo	DSS01	Examinar los mecanismos de monitoreo, registros del sistema, logs, dashboards y KPIs utilizados para el control y trazabilidad de los servicios tecnológicos.	Auditor TI
08/05/2026	08:00 – 12:00	Evaluación de infraestructura tecnológica y	Auditor TI	Infraestructura tecnológica	DSS01	Verificar la disponibilidad, estabilidad y capacidad operativa de la infraestructura tecnológica	Auditor TI

		disponibilidad de servicios				y servicios en la nube utilizados por la organización.	
08/05/2026	13:00 – 17:00	Evaluación de proveedores y servicios tecnológicos externos	Auditor TI	Gestión de terceros tecnológicos	DSS01	Verificar el cumplimiento de acuerdos de seguridad, confidencialidad y controles aplicados a proveedores y servicios tecnológicos externos.	Auditor TI
11/05/2026	08:00 – 12:00	Evaluación de gestión y respuesta ante incidentes tecnológicos	Auditor	Gestión de incidentes	DSS02	Examinar los procedimientos de identificación, registro, atención, escalamiento y respuesta ante incidentes de seguridad y fallos tecnológicos.	Auditor
11/05/2026	13:00 – 17:00	Evaluación de problemas recurrentes y análisis de causa raíz	Auditor TI	Gestión de problemas	DSS03	Analizar incidentes recurrentes, registros históricos, causas raíz y mecanismos implementados para prevenir fallos operativos repetitivos.	Auditor TI
12/05/2026	08:00 – 12:00	Evaluación de continuidad operativa y	Auditor líder	Continuidad del negocio	DSS04	Validar la existencia y eficacia de mecanismos de respaldo, recuperación,	Auditor líder

		recuperación de servicios				continuidad operativa y restauración de servicios críticos.	
12/05/2026	13:00 – 17:00	Evaluación de infraestructura de respaldo y disponibilidad operativa	Auditor TI	Continuidad tecnológica	DSS04	Verificar controles de respaldo, disponibilidad de servicios, redundancia y capacidad de recuperación ante interrupciones operativas.	Auditor TI
13/05/2026	08:00 – 12:00	Evaluación de servicios de seguridad y control de accesos	Auditor TI	Seguridad de accesos	DSS05	Verificar la gestión de accesos, autenticación de usuarios, asignación de roles, permisos y mecanismos de protección de la información.	Auditor TI
13/05/2026	13:00 – 17:00	Evaluación de controles de seguridad de la información	Auditor	Seguridad de la información	DSS05	Examinar la eficacia de los controles de seguridad implementados para garantizar la confidencialidad, integridad y disponibilidad de la información.	Auditor
14/05/2026	08:00 – 12:00	Revisión del tratamiento y protección de datos sensibles	Auditor	Gestión de datos sensibles	DSS05	Verificar el manejo seguro de datos sensibles, registros, grabaciones y procesos relacionados con	Auditor

						la protección de información confidencial.	
14/05/2026	13:00 – 17:00	Evaluación de controles operativos en herramientas de automatización e inteligencia artificial	Auditor TI	Automatización y tecnologías avanzadas	DSS05	Verificar la implementación de controles de seguridad y operación en herramientas de automatización e inteligencia artificial utilizadas por la empresa.	Auditor TI
15/05/2026	08:00 – 12:00	Evaluación de controles organizacionales y segregación de funciones	Auditor	Controles del negocio	DSS06	Validar la segregación de funciones, responsabilidades y controles administrativos implementados en los procesos organizacionales.	Auditor
15/05/2026	13:00 – 17:00	Evaluación de cumplimiento legal y políticas internas	Auditor legal/TI	Cumplimiento normativo	DSS06	Verificar el cumplimiento de normativas legales, políticas internas y lineamientos relacionados con la protección de datos y seguridad de la información.	Auditor legal/TI
18/05/2026	08:00 – 12:00	Identificación, clasificación y documentación de hallazgos	Equipo auditor	Evaluación general de controles	Fase VII	Identificar, documentar y clasificar hallazgos, desviaciones y oportunidades de mejora	Equipo auditor

						detectadas durante la auditoría.	
18/05/2026	13:00 – 17:00	Evaluación integral de controles internos bajo procesos DSS	Auditor líder	Control interno informático	Fase VII	Evaluar la eficacia del control interno informático con base en la evidencia recopilada y los procesos DSS evaluados durante la auditoría.	Auditor líder
19/05/2026	08:00 – 12:00	Elaboración del informe final de auditoría	Auditor líder	Informe de auditoría	Fase VII	Elaborar el informe final integrando hallazgos, riesgos, conclusiones y recomendaciones derivadas de la evaluación de controles y procesos DSS.	Auditor líder
19/05/2026	13:00 – 17:00	Reunión de cierre y presentación de resultados	Equipo auditor	Dirección	Fase VII	Presentar los resultados de la auditoría, conclusiones y recomendaciones a la dirección y partes interesadas de la organización.	Equipo auditor, Gerencia General

La figura 2 presenta las funciones y responsabilidades asignadas al equipo auditor dentro del plan de auditoría.

Figura 2

FUNCIONES Y RESPONSABILIDADES			
Auditor líder: Responsable de la planificación, dirección y supervisión de la auditoría. Coordina al equipo auditor, valida el alcance, aprueba los procedimientos, consolida los hallazgos y elabora el informe final. Asimismo, se encarga de la comunicación con la dirección y la resolución de conflictos durante el proceso. Auditor TI: Encargado de evaluar los aspectos técnicos del sistema de información, incluyendo infraestructura tecnológica, seguridad informática, redes, sistemas (CRM, dialers), controles de acceso, monitoreo y continuidad operativa. Aplica pruebas técnicas y valida configuraciones del sistema. Auditor (general): Responsable de ejecutar las actividades de auditoría relacionadas con procesos organizacionales, cumplimiento normativo, gestión de datos, políticas y control internos. Apoya en la recolección de evidencia y documentación de hallazgos. Observaciones: Nota 1: El plan de auditoría establecido puede sufrir las variaciones necesarias con base al desarrollo de la auditoría y las necesidades de los procesos auditados			
ELABORADO POR: (Nombre y Cargo)	FECHA	APROBADO POR: (Nombre y Cargo)	FECHA
Ing. Jade Esmeralda López González - Contratista	16/04/2026	Msc. Ing. Leonel Martínez Zúñiga – Licenciado en Derecho, Ingeniero en Computación	00/04/2026

Los resultados presentados a continuación fueron obtenidos mediante la aplicación del Cuestionario de Evaluación de Capacidad de Procesos y del Instrumento de Evaluación de Cumplimiento basado en las Disposiciones Técnicas DGI No. 03-2007 y No. 09-2007 adaptadas a entornos SaaS. La información recopilada mediante estos instrumentos permitió evaluar el grado de cumplimiento de los controles establecidos en los procesos DSS01, DSS04 y DSS05 de COBIT 5, así como identificar las principales debilidades relacionadas con la seguridad de la información, continuidad operativa y gestión de accesos dentro de la organización.

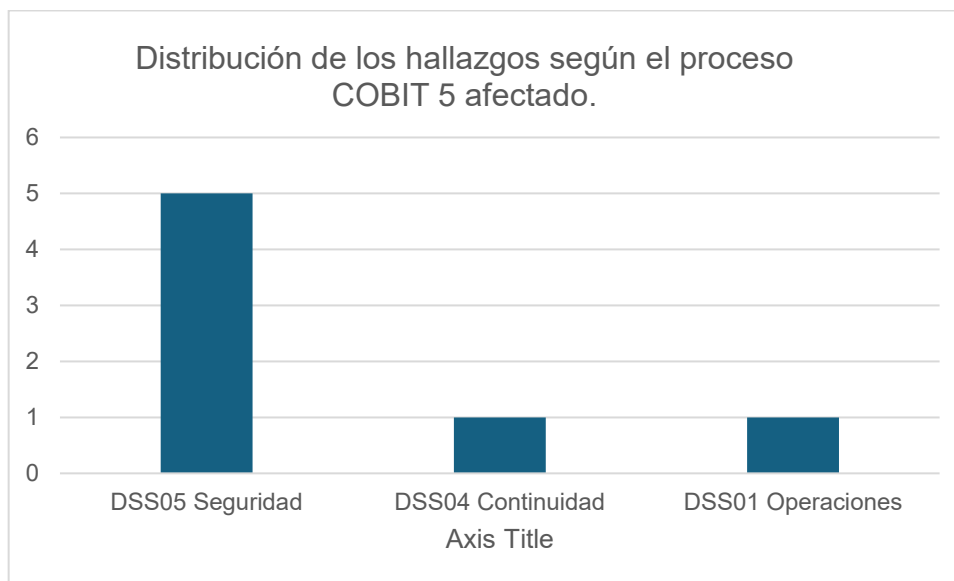
Gráfico 1. Hallazgos por proceso COBIT 5

El análisis de los hallazgos identificados durante la auditoría evidencia que el proceso DSS05 – Gestionar Servicios de Seguridad concentra el 71% de las observaciones detectadas. Los incumplimientos encontrados corresponden principalmente a la ausencia de autenticación multifactor (H1), la existencia de privilegios excesivos en cuentas operativas (H3 y H4), la falta de segregación adecuada de funciones y el uso de credenciales compartidas (H6). Estas condiciones reflejan debilidades significativas en la gestión de accesos y en la protección de la información sensible administrada por la organización. (Información obtenida mediante el Cuestionario de Evaluación de Capacidad de Procesos. Ver Anexo A, Evidencias H1, H3, H4 y H6).

En el proceso DSS04 – Gestionar la Continuidad se identificó un incumplimiento relacionado con la ausencia de un Plan de Recuperación ante Desastres formalmente documentado y la falta de evidencia de pruebas periódicas de restauración (H5). Esta situación limita la capacidad de recuperación de los servicios tecnológicos ante incidentes que afecten la disponibilidad de la

información. (Información obtenida mediante el Instrumento de Evaluación de Cumplimiento DGI. Ver Anexo A, Evidencia H5).

Respecto al proceso DSS01 – Gestionar Operaciones, se detectaron deficiencias en la configuración operativa del sistema de marcación automática (dialer), generando múltiples intentos de contacto en periodos reducidos de tiempo hacia un mismo usuario (H7), situación que puede afectar la calidad del servicio y la experiencia del cliente. (Información obtenida mediante el Cuestionario de Evaluación de Capacidad de Procesos. Ver Anexo, Evidencia H7).

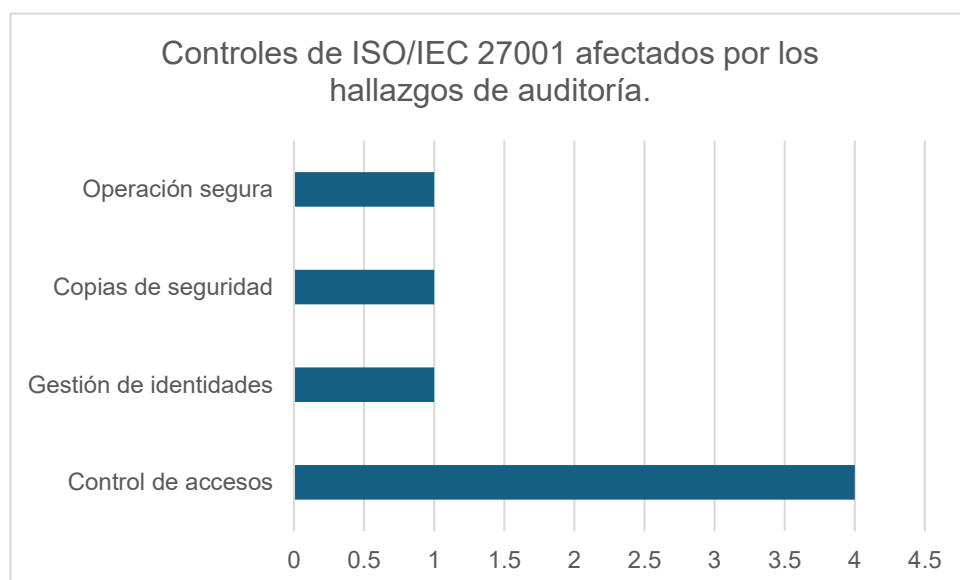


Proceso	Cantidad
DSS05 Seguridad	5
DSS04 Continuidad	1
DSS01 Operaciones	1

Gráfico 2. Hallazgos por control ISO/IEC 27001

Los resultados muestran que la mayor cantidad de incumplimientos se encuentra asociada a los controles de acceso definidos por la norma ISO/IEC 27001. Se identificaron debilidades relacionadas con la inexistencia de mecanismos de autenticación robusta (H1), permisos de acceso excesivos (H3 y H4), capacidades de exportación de información sin restricciones adecuadas (H2) y deficiencias en la gestión de identidades derivadas del uso de credenciales compartidas (H6). Estas observaciones afectan la capacidad de la organización para garantizar la protección adecuada de la información sensible. (Información obtenida mediante el Cuestionario de Evaluación de Capacidad de Procesos. Ver Anexo, Evidencias H1, H2, H3, H4 y H6).

Adicionalmente, se identificaron incumplimientos relacionados con los controles de copias de seguridad y operación segura de los sistemas, evidenciando la necesidad de fortalecer los mecanismos de continuidad operativa y supervisión tecnológica. (Información obtenida mediante el Instrumento de Evaluación de Cumplimiento DGI. Ver Anexo, Evidencias H5 y H7).



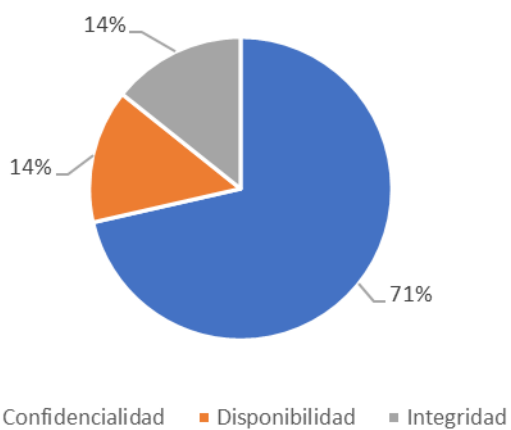
Control	Cantidad
Control de accesos	4
Gestión de identidades	1
Copias de seguridad	1
Operación segura	1

Gráfico 3. Relación Hallazgos vs Principios de Seguridad ISO 27001

Los resultados reflejan que el principio de confidencialidad es el más comprometido, representando el 71% de los hallazgos identificados. Esta situación se debe principalmente a las debilidades detectadas en la gestión de accesos, asignación de privilegios y protección de información sensible. La exposición de estos riesgos podría facilitar accesos no autorizados y comprometer la privacidad de los datos administrados por la organización. (Información obtenida mediante el Cuestionario de Evaluación de Capacidad de Procesos. Ver Anexo, Evidencias H1, H2, H3, H4 y H6).

Por otra parte, los principios de disponibilidad e integridad presentan una menor proporción de hallazgos; sin embargo, las observaciones relacionadas con la ausencia de mecanismos de recuperación (H5) y los problemas operativos detectados en el sistema de llamadas (H7) representan riesgos que podrían afectar la continuidad y confiabilidad de los servicios tecnológicos. (Información obtenida mediante el Instrumento de Evaluación de Cumplimiento DGI. Ver Anexo, Evidencias H5 y H7).

Impacto de los hallazgos sobre la confidencialidad, integridad y disponibilidad.

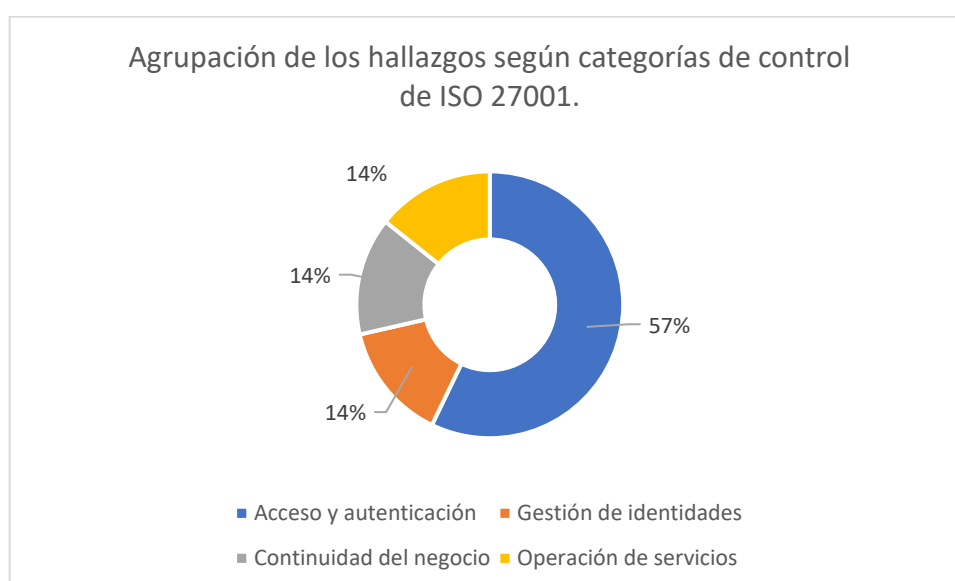


Principio	Cantidad	porcentaje
Confidencialidad	5	71%
Disponibilidad	1	14%
Integridad	1	14%

Gráfico 4. Hallazgos agrupados por categoría ISO 27001

La agrupación de hallazgos evidencia que la principal área de incumplimiento corresponde a los controles de acceso y autenticación, representando el 57% del total de observaciones. Este resultado confirma que la gestión de usuarios y privilegios constituye el principal punto de riesgo para la organización. (Información obtenida mediante el Cuestionario de Evaluación de Capacidad de Procesos). Ver Anexo, Evidencias H1, H2, H3 y H4).

Las categorías de gestión de identidades, continuidad del negocio y operación de servicios presentan una participación menor dentro de los hallazgos identificados; sin embargo, continúan representando riesgos relevantes debido a su impacto potencial sobre la seguridad, disponibilidad y confiabilidad de la información y de los servicios tecnológicos. (Información obtenida mediante el Instrumento de Evaluación de Cumplimiento DGI. Ver Anexo, Evidencias H5, H6 y H7).



Categoría	Cantidad	Porcentaje
Acceso y autenticación	4	57%
Gestión de identidades	1	14%
Continuidad del negocio	1	14%
Operación de servicios	1	14%

Resultados de las pruebas realizadas

Como resultado de la aplicación del Cuestionario de Evaluación de Capacidad de Procesos y del Instrumento de Evaluación de Cumplimiento basado en las Disposiciones Técnicas DGI, se identificó que el sistema utiliza únicamente mecanismos de autenticación basados en usuario y contraseña, sin implementar autenticación multifactor (H1). Asimismo, se observó la existencia de permisos incompatibles con las funciones asignadas a determinados usuarios, permitiendo el acceso a funcionalidades administrativas y la exportación de información sensible (H2, H3 y H4). (Ver Anexo, Evidencias H1, H2, H3 y H4).

Adicionalmente, se determinó la ausencia de evidencias documentadas de pruebas periódicas de restauración de respaldos y de un Plan de Recuperación ante Desastres formalmente establecido (H5). También se identificó exposición de información sensible en direcciones URL (H6) y anomalías operativas en la configuración del sistema de marcación automática (H7). (Ver Anexo, Evidencias H5, H6 y H7).

En conjunto, los resultados obtenidos demuestran la existencia de debilidades significativas en los controles de acceso, gestión de identidades, continuidad operativa y seguridad de la información, afectando principalmente los procesos DSS05, DSS04 y DSS01 de COBIT 5.

Determinación de la Opinión de Auditoría

Con el propósito de establecer una opinión objetiva sobre el estado de los controles evaluados, se analizaron los resultados obtenidos mediante la aplicación del Cuestionario de Evaluación de Capacidad de Procesos y del Instrumento de Evaluación de Cumplimiento basado en las Disposiciones Técnicas DGI No. 03-2007 y No. 09-2007 adaptadas a entornos SaaS.

La evaluación permitió identificar siete hallazgos distribuidos en los procesos DSS05 – Gestionar Servicios de Seguridad, DSS04 – Gestionar la Continuidad y DSS01 – Gestionar Operaciones del marco COBIT 5. Los resultados evidenciaron que las principales debilidades se concentran en la gestión de accesos y autenticación, la continuidad operativa y la operación de servicios tecnológicos.

Criterio para la emisión de la opinión

La opinión de auditoría se determinó considerando la cantidad, naturaleza e impacto de los hallazgos identificados, así como el efecto potencial que estos pueden generar sobre la confidencialidad, integridad y disponibilidad de la información.

Opinión de Auditoría		Descripción
Sin Salvedades		No se identifican hallazgos significativos que afecten el control interno.
Con Salvedades		Existen deficiencias relevantes que requieren atención, pero no comprometen totalmente la operación de la organización.
Adversa		Se identifican deficiencias críticas que comprometen significativamente el control interno y la operación de la organización.

Interpretación de los resultados

Los resultados obtenidos evidencian que la organización dispone de controles y procedimientos que permiten la operación de sus servicios tecnológicos. Sin embargo, se identificaron deficiencias relacionadas con la gestión de accesos, asignación de privilegios, continuidad operativa y configuración de servicios, las cuales representan riesgos que deben ser atendidos para fortalecer el control interno y la seguridad de la información.

Considerando que las debilidades identificadas no comprometen totalmente la operación de la organización, pero sí requieren acciones correctivas prioritarias, corresponde emitir una Opinión con Salvedades.

CONCLUSIONES

De acuerdo con los resultados obtenidos, el equipo auditor **Auditors Inc.** emite una Opinión con Salvedades, debido a las deficiencias identificadas en la gestión de accesos y autenticación, continuidad operativa y operación de servicios tecnológicos.

Las principales deficiencias detectadas se concentraron en la gestión de accesos y autenticación, evidenciando la ausencia de mecanismos sólidos de identificación, la asignación de privilegios excesivos a roles operativos y la falta de trazabilidad individual derivada del uso de credenciales compartidas. Asimismo, se identificaron debilidades en la continuidad operativa, debido a la ausencia de un Plan de Recuperación ante Desastres formal, así como en la configuración operativa del sistema de marcación automática, lo que impacta en la calidad del servicio.

Cabe señalar que la organización dispone de una infraestructura tecnológica funcional y procesos básicos documentados que permiten el desarrollo de sus operaciones y la prestación de sus servicios. No obstante, persisten brechas significativas en materia de seguridad de la información, gestión de accesos y continuidad operativa que requieren atención prioritaria para salvaguardar la confidencialidad, integridad y disponibilidad de la información.

Período de cobertura de la auditoría: mayo de 2026.

Instrumentos

CUESTIONARIO DE EVALUACIÓN DE CAPACIDAD DE PROCESOS

Auditoría: Central Legal Advisors

Fecha: junio 2026

Auditor: Auditor Líder

INSTRUCCIONES DE APLICACIÓN

Este cuestionario está diseñado para ser aplicado al Área de TI, Gerencia General y Responsables Operativos de Central Legal Advisors. Cada pregunta evalúa la implementación y eficacia de prácticas de gestión específicas del marco COBIT 5.

NIVEL	CAPACIDAD	CRITERIO
0	Incompleto	La práctica no se realiza o no existe evidencia
1	Realizado	La práctica se realiza de manera informal, sin documentación
2	Gestionado	La práctica se realiza siguiendo un procedimiento documentado
3	Establecido	La práctica se realiza bajo un proceso estandarizado en toda la organización
4	Predecible	La práctica se mide y se toman acciones correctivas basadas en métricas
5	Optimizado	La práctica se mejora continuamente basada en retroalimentación

N.º	PREGUNTA	PROCESO DE GESTIÓN COBIT 5	VALOR (0-5)	RESPUESTAS
DSS01 – Gestionar Operaciones				
1	¿Existen procedimientos operativos documentados para la ejecución de las actividades diarias de TI?	DSS01.01 Ejecutar procedimientos operativos	3	Existen manuales y procedimientos visibles en el área de TI. Se considera establecido .
2	¿El personal conoce y aplica los procedimientos operativos establecidos?	DSS01.01 Ejecutar procedimientos operativos	3	Se evidencia conocimiento general del personal operativo sobre sus tareas, aunque hay desviaciones en seguridad.
3	¿Se monitorea continuamente el funcionamiento del CRM, Dialer y demás sistemas tecnológicos?	DSS01.03 Supervisar la infraestructura de TI	3	Se realiza monitoreo básico
4	¿Se revisan periódicamente los registros (logs) de los sistemas para detectar anomalías?	DSS01.03 Supervisar la infraestructura de TI	2	Se revisan ocasionalmente.
5	¿Existen indicadores o métricas para medir el desempeño de las operaciones de TI?	DSS01.03 Supervisar la infraestructura de TI	3	La empresa mide disponibilidad y rendimiento básico. Se asume establecido .
6	¿Los servicios tecnológicos proporcionados por terceros son supervisados y evaluados periódicamente?	DSS01.02 Gestionar servicios externalizados de TI	3	Supervisión básica de proveedores cloud.
7	¿Se realizan respaldos periódicos de la información crítica de la organización?	DSS01.04 Gestionar el entorno	4	Bueno - existen respaldos automáticos en la nube.
DSS02 - Gestionar Solicitudes de Servicio e Incidentes				
8	¿existe un procedimiento documentado para el registro y gestión de incidentes de seguridad (accesos no autorizados, fugas de información)?	DSS02.04 - Establecer procedimiento de gestión de incidentes	3	Existen de manera general
9	¿Se ha capacitado al personal sobre cómo reportar incidentes de seguridad o actividades sospechosas?	DSS02.04 - Capacitar al personal en reporte de incidentes	3	Se brinda capacitación ocasional
10	¿Existe un registro histórico de incidentes de seguridad que documente causas, acciones tomadas y lecciones aprendidas?	DSS02.04 - Mantener bitácora histórica de incidentes	3	Existe evidencia de registros.
DSS03 – Gestionar Problemas				
11	¿Se documentan formalmente los problemas recurrentes en los sistemas (CRM, dialer)?	DSS03.01 Identificar problemas	3	Se documentan algunos casos.
12	¿Se realiza análisis de causa raíz para incidentes repetitivos?	DSS03.02 Analizar problemas	2	No siempre se realiza formalmente
13	¿Existe un registro histórico de problemas y sus soluciones?	DSS03.03 Resolver problemas	3	Se mantiene cierta documentación.
DSS04 – Gestionar Continuidad				
14	¿Existe un Plan de Recuperación ante Desastres (DRP) formalmente documentado y aprobado por la Gerencia?	DSS04.03 - Desarrollar y mantener planes de continuidad	0	No existe DRP documentado.

15	¿El DRP incluye objetivos específicos de Tiempo de Recuperación (RTO) y Punto de Recuperación (RPO) para los sistemas críticos (CRM, grabaciones, leads)?	DSS04.03 - Definir RTO y RPO para servicios críticos	0	No aplica porque no hay.
16	¿Se han realizado pruebas de restauración (simulacros) de los respaldos en los últimos 12 meses?	DSS04.03 - Ejecutar pruebas periódicas de continuidad	0	No hay evidencia de pruebas de restauración.
17	¿Las pruebas de restauración incluyen la verificación de la integridad de los datos recuperados (archivos legibles y utilizables)?	DSS04.03 - Validar efectividad de los procedimientos de recuperación	0	No aplica
18	¿Existe un cronograma formal para la ejecución de pruebas de restauración (mínimo semestral)?	DSS04.03 - Establecer programa de pruebas de continuidad	0	No aplica
19	¿La política de respaldos define claramente la frecuencia, retención y ubicación de las copias de seguridad?	DSS04.03 - Definir política de respaldos	4	Bueno – se reconoce respaldos automáticos en nube, lo que implica política definida.
20	¿Existe evidencia de que los respaldos se ejecutan automáticamente según lo programado sin fallos recurrentes?	DSS04.03 - Monitorear ejecución de respaldos	4	Bueno – indica que los respaldos funcionan automáticamente.
DSS05 – Gestionar Servicios de Seguridad				
21	¿Existe una política formal de seguridad de la información aprobada por la organización?	DSS05.04 Gestionar identidad y acceso lógico	2	Existe algo básico, pero el incumplimiento en accesos muestra que no es efectiva.

22	¿Cada usuario posee credenciales únicas para acceder a los sistemas?	DSS05.04 Gestionar identidad y acceso lógico	1	Credenciales genéricas compartidas.
23	¿Los permisos de acceso son asignados según las funciones y responsabilidades del usuario?	DSS05.04 Gestionar identidad y acceso lógico	1	Usuarios con permisos que no corresponden (botones de eliminar, exportar, rol de administrador).
24	¿Se utiliza autenticación multifactor para accesos críticos?	DSS05.04 Gestionar identidad y acceso lógico	0	No se implementa MFA.
25	¿Se monitorean los intentos de acceso no autorizado?	DSS05.07 Monitorear eventos de seguridad	2	Control limitado– relación con permisos de admin sin detección.
26	¿Existe control sobre el acceso a grabaciones de llamadas y datos sensibles?	DSS05.04 Gestionar identidad y acceso lógico	1	Usuarios de Qualifying pueden descargar grabaciones sin necesidad.
27	¿Los colaboradores reciben capacitación periódica sobre phishing y seguridad informática?	DSS05.03 Gestionar seguridad de red y conectividad	4	Bueno – aunque son capacitaciones básicas, pero si se realizan.
28	¿Se utilizan herramientas de protección contra malware en los equipos corporativos?	DSS05.01 Proteger contra malware	2	Si existen pero con debilidades.
DSS06 – Gestionar Controles del Negocio				
29	¿Existen políticas internas documentadas para el manejo de datos sensibles?	DSS06.01 Definir controles	3	Existe manual de funciones y políticas internas, pero no se cumplen cabalmente.

30	¿Se cumple con la Ley 787 de Protección de Datos Personales en las grabaciones de llamadas?	DSS06.02 Cumplimiento normativo	2	Existen incumplimientos relacionados con acceso a datos
31	¿Se realizan auditorías internas para verificar el cumplimiento de políticas de TI?	DSS06.03 Monitorear controles	3	Se realizan revisiones periódicas.

INSTRUMENTO DE EVALUACIÓN DE CUMPLIMIENTO BASADO EN LAS DISPOSICIONES TÉCNICAS DGI

No. 03-2007 Y No. 09-2007 (ADAPTADO A ENTORNOS SaaS)

N°	Criterio de evaluación	Referencia normativa DGI	C	NC	NA	Evidencia
1	El sistema controla el acceso mediante nombre de usuario y contraseña.	DT 03-2007, Ordinal Segundo, numeral 2. Seguridad de acceso.	X			La empresa utiliza mecanismos de autenticación mediante usuario y contraseña para acceder a los sistemas de información y plataformas tecnológicas.
2	El sistema controla el acceso mediante credenciales únicas para cada usuario.	DT 09-2007, Ordinal Segundo, numeral 1.3 Seguridad de Acceso.	X			Se evidencia la gestión de usuarios y permisos individuales dentro del sistema, permitiendo la asignación de credenciales específicas.
3	Existen procedimientos documentados para el respaldo de la información.	DT 03-2007, Ordinal Segundo, numeral 1.6.	X			Existen procedimientos relacionados con respaldo y recuperación de información dentro de las políticas y controles identificados.
4	El sistema realiza respaldos periódicos de la información almacenada.	DT 03-2007, Ordinal Segundo, numeral 7. Respaldo de información.	X			Se identificó la existencia de un sistema de respaldos periódicos y registros de copias de seguridad como evidencia de control.
5	Los respaldos son almacenados en medios seguros que permiten la recuperación de información.	DT 03-2007, Ordinal Segundo, numeral 7. Respaldo de información.	X			La información se almacena en infraestructura cloud con controles de almacenamiento, cifrado y control de versiones administrados por AWS.
6	El sistema dispone de medidas de seguridad para proteger la información respaldada.	DT 03-2007, Ordinal Segundo, numeral 7. Respaldo de información.	X			Los respaldos cuentan con medidas de protección como cifrado y controles de acceso sobre la información almacenada.

7	Existe un plan de contingencia para garantizar la continuidad de las operaciones ante fallas tecnológicas.	DT 03-2007, Ordinal Segundo, numeral 6. Plan de contingencia.	X			La organización contempla mecanismos de continuidad operativa y recuperación de servicios dentro de su gestión tecnológica.
8	El plan de contingencia contempla la recuperación e integridad de la información procesada por el sistema.	DT 03-2007, Ordinal Segundo, numeral 6. Plan de contingencia.	X			El plan de continuidad considera respaldos, recuperación de información y restauración de servicios críticos.
9	Se dispone de manual técnico del sistema.	DT 03-2007, Ordinal Segundo, numeral 8. Documentación.		X		No se encontró evidencia documental que confirme la existencia de un manual técnico formal del sistema utilizado por la organización.
10	Se dispone de manual de usuario actualizado.	DT 03-2007, Ordinal Segundo, numeral 8. Documentación.		X		No se identificó evidencia de un manual de usuario actualizado para los diferentes sistemas y herramientas tecnológicas empleadas.
11	Existe documentación que describa las características y funcionamiento del software utilizado.	DT 03-2007, Ordinal Segundo, numeral 1.5.	X			El diagnóstico describe las características, componentes y funcionamiento general del software, CRM, dialers y herramientas utilizadas.
12	Los cambios o modificaciones significativas realizados al sistema son documentados y controlados.	DT 03-2007, Ordinal Segundo, numeral 9. Imprevistos.	X			Se contempla documentación de configuraciones, mantenimiento del CRM y gestión de cambios asociados a la operación tecnológica.

13	Los cambios realizados al sistema cuentan con evidencia de autorización o aprobación.	DT 09-2007, Ordinal Segundo, numeral 1.6. Notificación de Imprevistos.		X		No se encontró evidencia específica de autorizaciones formales o aprobaciones documentadas para modificaciones significativas del sistema.
14	La organización conserva la información y documentación generada por el sistema para fines de auditoría y verificación.	DT 03-2007, Ordinal Segundo, numeral 5. Conservación de documentación.	X			La organización conserva registros, logs, grabaciones, reportes y documentación utilizados para monitoreo y auditoría.
15	El sistema garantiza la integridad de la información procesada y almacenada.	DT 03-2007, Ordinal Segundo, numeral 6. Integridad de la información en contingencias.	X			Existen controles de acceso, monitoreo, respaldo y protección de datos orientados a garantizar la integridad de la información procesada.
16	Existen mecanismos para verificar la disponibilidad y recuperación de la información respaldada.	DT 09-2007, Ordinal Segundo, numeral 1.4. Respaldo de soportes.		X		Aunque existen respaldos periódicos, no se evidencian pruebas formales de restauración o validación periódica de recuperación de la información. De hecho, una de las recomendaciones es fortalecer dichas pruebas.

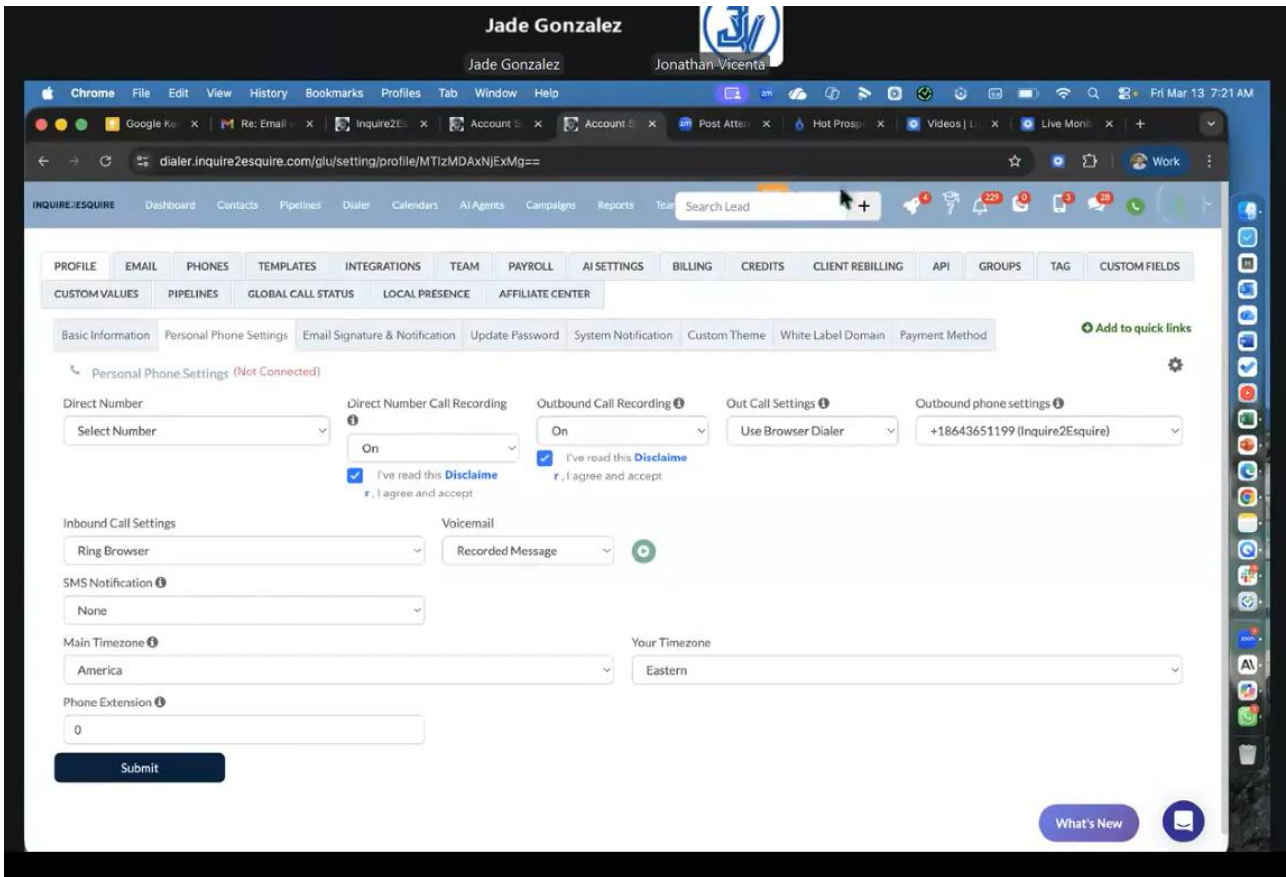
Central Legal Advisors presenta un nivel de cumplimiento aceptable respecto a los controles evaluados bajo las Disposiciones Técnicas DGI No. 03-2007 y No. 09-2007 adaptadas a entornos SaaS. Las principales brechas se relacionan con la formalización documental (manuales), la gestión formal de cambios y la evidencia de pruebas de recuperación de respaldos. Se concluye con un 75% de cumplimiento

Observación Directa

FORMATO DE REVISIÓN DOCUMENTAL Y OBSERVACIÓN

Documento revisado	Existe	Vigente	Evidencia	Observaciones
Política de seguridad	☒	☐	No se presentó documentación formal que establezca controles de seguridad, gestión de accesos o protección de datos.	Se recomienda elaborar y aprobar una Política de Seguridad de la Información alineada con ISO/IEC 27001.
Manual de funciones	☒	☒	Se identificaron funciones operativas definidas para los usuarios del sistema.	Aunque existen funciones definidas, se observaron privilegios excesivos en algunas cuentas, evidenciando debilidades en la segregación de funciones.
Registro de accesos	☒	☒	Se verificó la existencia de usuarios, roles y permisos dentro de la plataforma.	Se identificó uso de credenciales compartidas y ausencia de mecanismos robustos de autenticación, afectando la trazabilidad individual.
Logs del sistema	☒	☒	Se revisaron registros de actividad y accesos	No se evidenciaron controles suficientes para garantizar la identificación

			disponibles en la plataforma.	individual de todas las acciones realizadas por los usuarios.
Reportes / dashboards	☒	☒	Se observaron reportes operativos y paneles de seguimiento utilizados para la gestión de actividades.	Los reportes apoyan el monitoreo operativo; sin embargo, no sustituyen controles formales de seguridad y monitoreo de accesos.
Procedimientos de respaldo	☒	☐	Se confirmó la existencia de respaldos operativos administrados por el proveedor cloud.	No se presentó evidencia de pruebas periódicas de restauración ni de un Plan de Recuperación ante Desastres formalmente documentado.

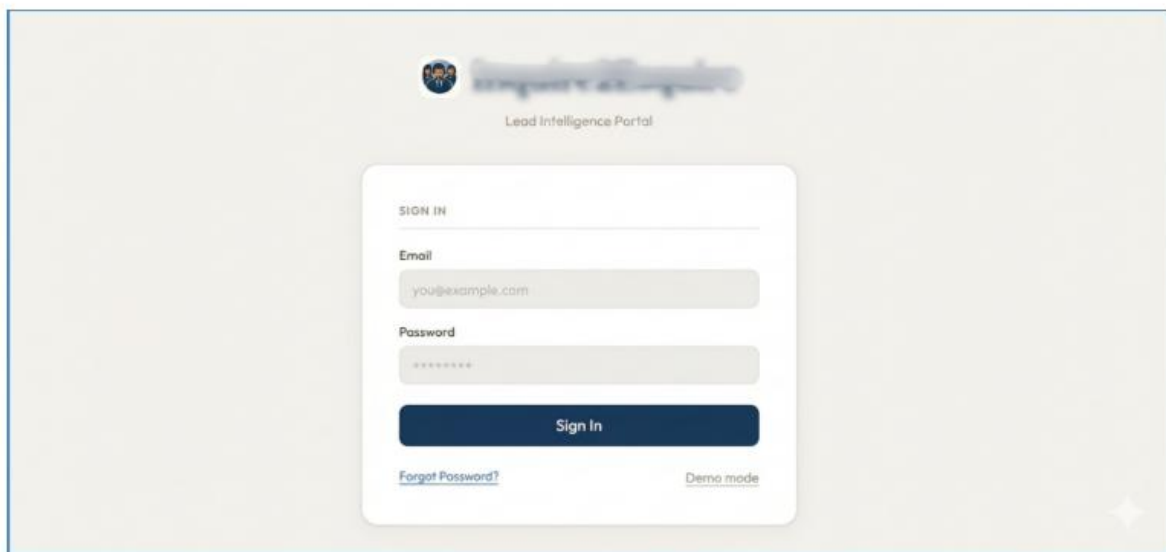


Evidencia complementaria: La imagen adjunta muestra el enlace de acceso a una sesión grabada utilizada durante la auditoría para observar el funcionamiento operativo del sistema, constituyendo evidencia de apoyo para la evaluación del proceso DSS01 – Gestionar Operaciones de COBIT 5.

Evidencia de Hallazgos

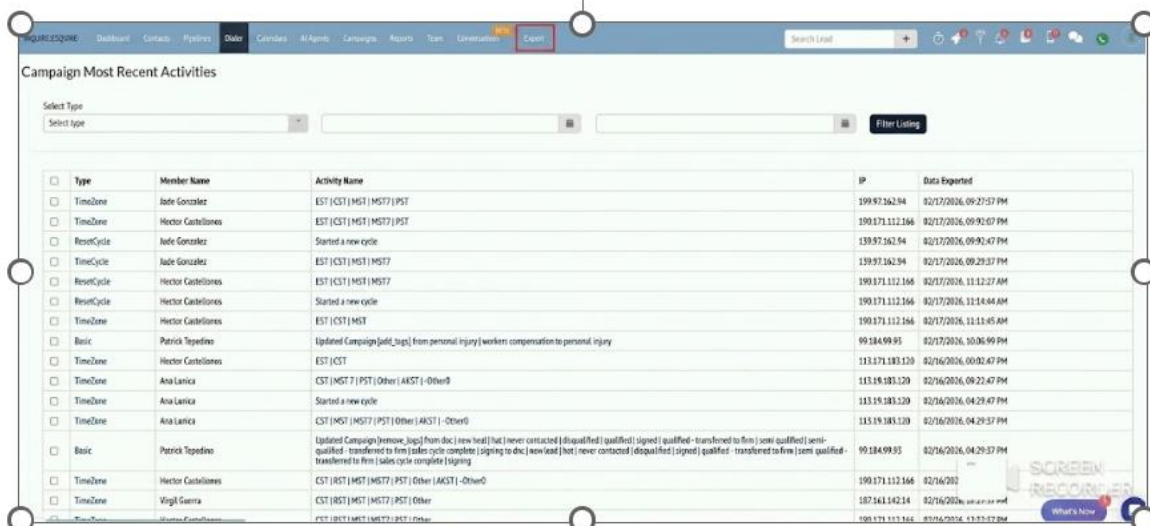
Hallazgo 1

Se verificó que el proceso de autenticación únicamente solicita usuario y contraseña. No se detectó requerimiento de segundo factor de autenticación durante el acceso al sistema.



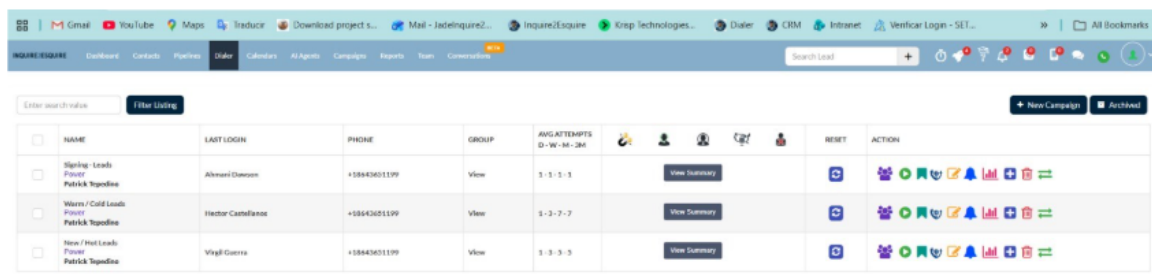
Hallazgo 2

Mediante pruebas funcionales se identificó disponibilidad de exportación de registros en formato .csv/.xlsx. No se evidenciaron controles adicionales de validación o restricción.



Hallazgo 3

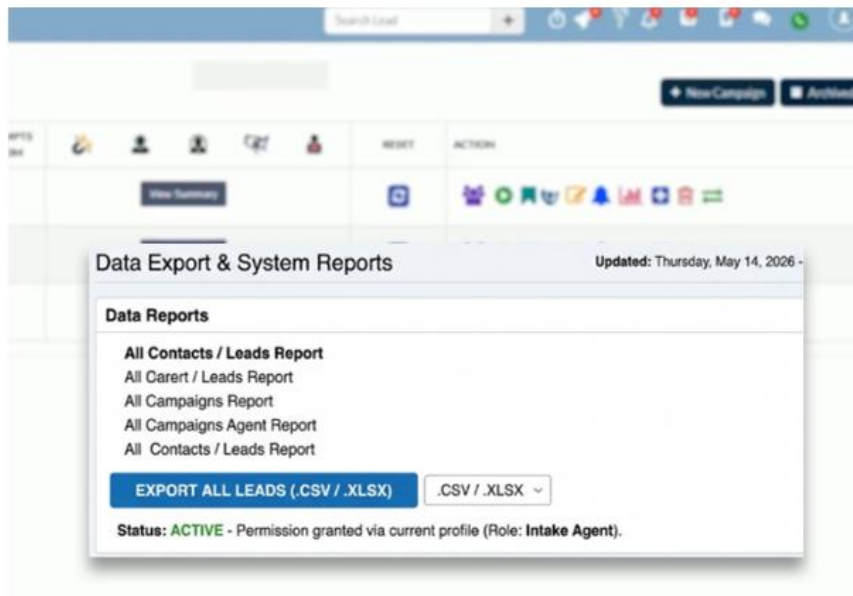
Durante pruebas de navegación se visualizaron funciones “Eliminar lead” y “Descargar grabación” en perfiles operativos. Se verificaron permisos incompatibles con el rol asignado.



NAME	LAST LOGIN	PHONE	GROUP	ACTIONS	RESET	ACTION
Sigrid / Leads Patric Tzopline	Alfred Dawson	+5843651199	View	3-1-1-1	View Summary	Icons for various actions
Wiem / Cold Leads Patric Tzopline	Hector Castellano	+5843651199	View	3-2-7-7	View Summary	Icons for various actions
New / Hot Leads Patric Tzopline	Virgil Guerra	+5843651199	View	3-3-3-3	View Summary	Icons for various actions

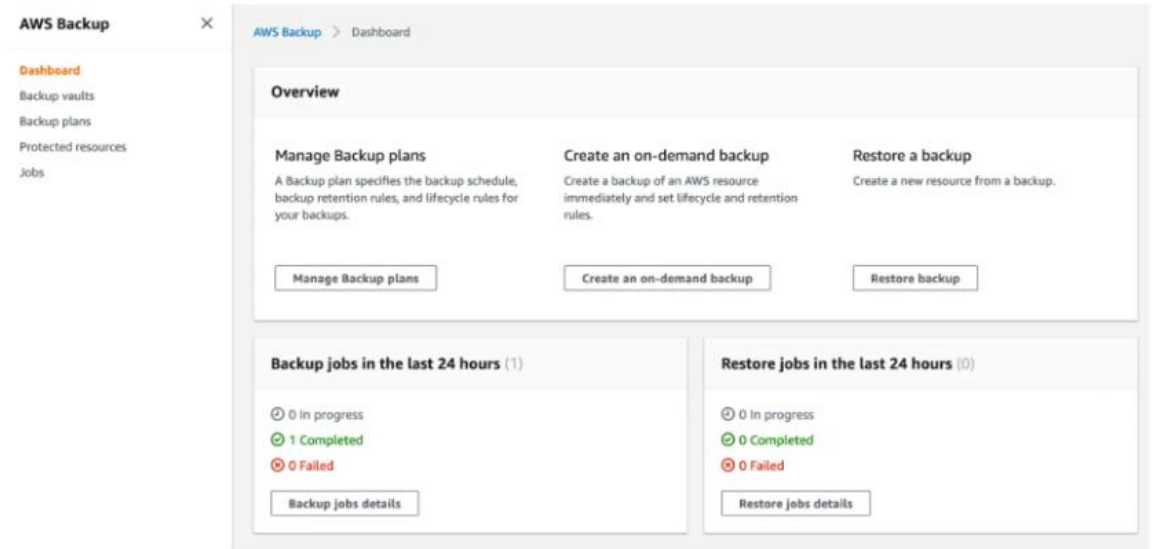
Hallazgo 4

Durante pruebas de recorrido en el CRM, se visualizó el acceso a funciones de 'Exportación masiva de registros' (.csv / .xlsx) y 'Configuración global de sistema' en perfiles de Intake y Qualifying.



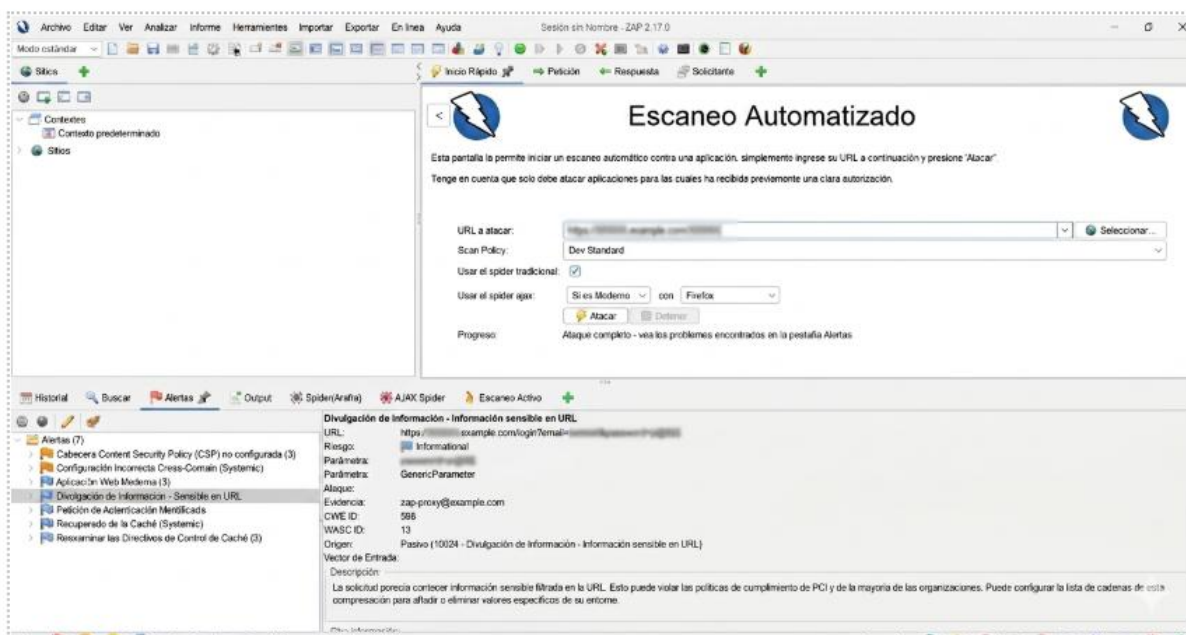
Hallazgo 5

Si bien la organización realiza respaldos automáticos en la nube, el área de T1 no mostr
evidencias de el "Historial de pruebas de restauración" o los "Formatos de simulacros del
último año"



Hallazgo 6

Análisis realizado mediante OWASP ZAP, Alerta detectada: “Divulgación de Información – Información sensible en URL”, CWE identificado: CWE-598, Parámetro expuesto detectado en solicitud HTTP GET, Evidencia respaldada mediante captura de herramienta OWASP ZAP.



Hallazgo 7

Captura de pantalla del panel de historial de llamadas del sistema dialer (Hot Prospector), correspondiente al contacto del operador "Virgil Guerra" (teléfono 12702453558), donde se visualizan 3 intentos de llamada a un mismo número en un intervalo menor a 1 minuto.

The screenshot displays the Hot Prospector dialer system interface. At the top, the user is logged in as 'Virgil Guerra' with a status of 'Available'. The interface shows a call log for a specific number, 12702453558, with three call attempts listed. The first two attempts are marked as 'No Answer' and the third as 'Call Status: 01 (770) 243-5358 - No Answer (Duration: 35 sec)'. The interface also includes a 'Show Last Notes' section on the left, a central form for contact details (Name, Company, Email, Address, etc.), and a 'Call Attempts' section on the right with a list of status options like 'Call Block', 'No Answer', 'Hang Up', etc.

Call Log:

Time	Call Status	Duration
11:00:00 AM	No Answer	
11:00:05 AM	No Answer	
11:00:10 AM	Call Status: 01 (770) 243-5358 - No Answer	35 sec

Contact Details:

Field	Value
First Name	Virgil
Last Name	Guerra
Company	Insure2Explore
Email	headburke@insure2explore.com
Country Code	US - CA (+1)
Mobile Number	(770) 243-5358
Phone Type	Mobile
Address	12702453558
City	San Francisco
State	CA
Zipcode	94102
Additional Information	

Call Attempts:

Attempt	Status
1	Call Block
2	No Answer
3	Hang Up
4	Call Status
5	Call Status
6	Call Status
7	Call Status
8	Call Status
9	Call Status
10	Call Status
11	Call Status
12	Call Status
13	Call Status
14	Call Status
15	Call Status
16	Call Status
17	Call Status
18	Call Status
19	Call Status
20	Call Status
21	Call Status
22	Call Status
23	Call Status
24	Call Status
25	Call Status
26	Call Status
27	Call Status
28	Call Status
29	Call Status
30	Call Status
31	Call Status
32	Call Status
33	Call Status
34	Call Status
35	Call Status
36	Call Status
37	Call Status
38	Call Status
39	Call Status
40	Call Status
41	Call Status
42	Call Status
43	Call Status
44	Call Status
45	Call Status
46	Call Status
47	Call Status
48	Call Status
49	Call Status
50	Call Status
51	Call Status
52	Call Status
53	Call Status
54	Call Status
55	Call Status
56	Call Status
57	Call Status
58	Call Status
59	Call Status
60	Call Status
61	Call Status
62	Call Status
63	Call Status
64	Call Status
65	Call Status
66	Call Status
67	Call Status
68	Call Status
69	Call Status
70	Call Status
71	Call Status
72	Call Status
73	Call Status
74	Call Status
75	Call Status
76	Call Status
77	Call Status
78	Call Status
79	Call Status
80	Call Status
81	Call Status
82	Call Status
83	Call Status
84	Call Status
85	Call Status
86	Call Status
87	Call Status
88	Call Status
89	Call Status
90	Call Status
91	Call Status
92	Call Status
93	Call Status
94	Call Status
95	Call Status
96	Call Status
97	Call Status
98	Call Status
99	Call Status
100	Call Status

